# AI Use-Case Governance Readiness Report — Cyber threat detection

> ***Synthetic example.*** *This report was generated from fictional data to illustrate AEGIS Agent output. It describes no real organization or system.*

| Field | Value |
|---|---|
| Report ID | rpt_mvi8hwacb51b6642 |
| Assessment ID | asm_mvi8hw6z5329f62c |
| AI system record | sys_mvi8hs8313cd7b41 |
| Generated (UTC) | 2026-10-21T14:55:25+00:00 |
| Prepared by | Synthetic AEGIS Analyst via AEGIS Agent |
| Question bank | AEGIS-UC-ASSESS v1.0.0 |
| Control library | AEGIS Control Library v1.0.0 |
| Evidence basis | Self-reported answers (User-asserted) unless evidence was reviewed by a named reviewer (Verified) |

## 1. Executive summary

- **Preliminary risk tier: High** (Inferred; requires human confirmation — Confirmed by Synthetic Head of AI Risk (2026-10-21)).
- **33 of 33** applicable questions answered across 7 modules.
- **31 gaps** identified: 2 Critical, 16 High, 12 Medium, 1 Low.
- **Evidence posture:** 2 finding(s) Verified by a named reviewer; 12 User-asserted; 17 Missing evidence; 2 Critical gap; 0 Inferred.
- **Priority actions (Critical, due within 30 days):**
  - GAP-001: Restrict data access to the minimum records and fields required, using scoped service identities, and review access periodically. (IS-03, IS-11; owner: DPO / Privacy Lead)
  - GAP-002: Define and enforce retention periods for prompts, outputs, transcripts and logs consistent with the privacy assessment. (IS-03, SE-02; owner: DPO / Privacy Lead)

This report indicates governance readiness and evidence gaps for one AI system. It is not a determination of conformity or legal compliance with any framework or law.

## 2. AI system profile

| Field | Value | Evidence status |
|---|---|---|
| name | Cyber threat detection | User-asserted |
| purpose | Detect anomalous network activity | User-asserted |
| domain_category | critical_infrastructure | User-asserted |
| decision_impact | advisory | User-asserted |
| affected_parties | internal | User-asserted |
| data_sensitivity | confidential | User-asserted |
| autonomy | suggests | User-asserted |
| external_actions | No | User-asserted |
| genai | No | User-asserted |
| vendor_model | Yes | User-asserted |
| eu_exposure | Yes | User-asserted |
| tools | — | User-asserted |

| Field | Value | Evidence status |
|---|---|---|
| environment | production | User-asserted |

## 3. Risk tier and rationale

**Tier:** High (score 60) — evidence status: Inferred; requires human confirmation: yes.

**Rationale:** Preliminary tier High (score 60). Drivers: decision_impact=advisory (+5); data_sensitivity=confidential (+10); autonomy=suggests (+5); domain_category=critical_infrastructure — Critical infrastructure (Annex III area 2) (+30); third_party_model=True (+5); eu_exposure=True (+5). Triggers: Potential EU AI Act high-risk area: Critical infrastructure (Annex III area 2) — legal classification review required (Art. 6). Inferred from user-provided intake; requires human confirmation.

| Factor | Value | Points | Citation |
|---|---|---|---|
| decision_impact | advisory | 5 | AEGIS Control GL-02: Pre-deployment risk and impact assessment (Control Library v1.0.0) |
| affected_parties | internal | 0 | AEGIS Control EI-04: Intended purpose and context of use (Control Library v1.0.0) |
| data_sensitivity | confidential | 10 | AEGIS Control IS-03: Privacy assessment and data minimisation (Control Library v1.0.0) |
| autonomy | suggests | 5 | AEGIS Control IS-09: Human oversight design (Control Library v1.0.0) |
| domain_category | critical_infrastructure — Critical infrastructure (Annex III area 2) | 30 | AEGIS Control AO-07: Regulatory and contractual obligations register (Control Library v1.0.0) |
| third_party_model | Yes | 5 | AEGIS Control GL-11: Vendor AI due diligence and contract controls (Control Library v1.0.0) |
| eu_exposure | Yes | 5 | AEGIS Control AO-07: Regulatory and contractual obligations register (Control Library v1.0.0) |

**Triggers:**

- Potential EU AI Act high-risk area: Critical infrastructure (Annex III area 2) — legal classification review required (Art. 6)
- Approval authority for this tier: AI Governance Forum
- Review cadence: every 6 months
- Assessment modules applied: Core governance & lifecycle, Data & privacy, Security & resilience, Fairness, safety & transparency, Human oversight & operations, Vendor & third-party AI, Monitoring, incidents & evidence
- Method: AEGIS risk-tier rules v1.0 (thresholds: High >= 60 or any high-risk trigger; Medium >= 30)

## 4. Domain heat map

| Domain | Qs | Implementation (self-reported) | Verified | Crit | High | Med | Low | Rating |
|---|---|---|---|---|---|---|---|---|
| Strategy & Accountability | 2 | 100.0% | 0 | 0 | 0 | 2 | 0 | Moderate exposure |
| AI Inventory & Visibility | 3 | 66.7% | 1 | 0 | 1 | 1 | 0 | High exposure |
| Risk Management & Lifecycle | 7 | 64.3% | 1 | 0 | 3 | 3 | 0 | High exposure |
| Data & Privacy | 5 | 10.0% | 0 | 2 | 3 | 0 | 0 | Critical exposure |
| Security & Resilience | 4 | 37.5% | 0 | 0 | 3 | 0 | 1 | High exposure |
| Fairness, Safety & Transparency | 4 | 50.0% | 0 | 0 | 2 | 2 | 0 | High exposure |
| Human Oversight & Operations | 5 | 60.0% | 0 | 0 | 2 | 3 | 0 | High exposure |

| Domain | Qs | Implementation (self-reported) | Verified | Crit | High | Med | Low | Rating |
|---|---|---|---|---|---|---|---|---|
| Assurance, Evidence & Improvement | 3 | 16.7% | 0 | 0 | 2 | 1 | 0 | High exposure |

Implementation indicator = implemented (1.0) and partial (0.5) answers as a share of applicable questions; it reflects self-reported answers, not verified evidence.

## 5. Gap register

| Gap · severity · due | Evidence status | Question | Controls | Owner role | Recommended action |
|---|---|---|---|---|---|
| GAP-001 · Critical · due 2026-11-20 | Critical gap | UC-DATA-Q4: Is the system's data access limited to the minimum records and fields it needs (e.g. field-level scoping of CRM access)? | IS-03, IS-11 | DPO / Privacy Lead | Restrict data access to the minimum records and fields required, using scoped service identities, and review access periodically. |
| GAP-002 · Critical · due 2026-11-20 | Critical gap | UC-DATA-Q5: Are retention periods defined and enforced for prompts, outputs, conversation transcripts and logs? | IS-03, SE-02 | DPO / Privacy Lead | Define and enforce retention periods for prompts, outputs, transcripts and logs consistent with the privacy assessment. |
| GAP-003 · High · due 2026-12-20 | Missing evidence | UC-DATA-Q2: Has a privacy / data-protection impact assessment been completed covering lawful basis, minimisation, retention and cross-border transfers? | IS-03 | DPO / Privacy Lead | Complete a privacy impact assessment (DPIA where required) covering lawful basis, minimisation, retention and transfers, signed off by the DPO/privacy lead. |
| GAP-004 · High · due 2026-12-20 | Missing evidence | UC-DATA-Q3: Are personal and sensitive fields redacted or masked before they reach prompts, logs and external model calls? | IS-04 | Platform Engineering / Privacy Lead | Deploy redaction/masking on prompts, responses, logs and external model calls; test it against representative records and retain the results. |
| GAP-005 · High · due 2026-12-20 | Missing evidence | UC-SEC-Q3: Is there a tested kill switch and rollback procedure that can disable the system, model, agent or individual tools quickly? | IS-15 | Platform Engineering / SRE | Implement and test a kill switch and rollback runbook; record time-to-disable from the test. |
| GAP-006 · High · due 2026-12-20 | Missing evidence | UC-CORE-Q2: Are the intended purpose, context of use, users, affected parties and out-of-scope uses documented? | EI-04 | Product Owner | Document intended purpose, context of use, users, affected parties and explicitly out-of-scope or foreseeable misuse. |
| GAP-007 · High · due 2026-12-20 | Missing evidence | UC-CORE-Q7: Are changes to the model, prompts, data, tools or vendor subject to change control with defined reassessment triggers? | GL-04, EI-05 | Engineering / Change Advisory Board | Add AI-specific change triggers (model, prompt, data, tool, vendor) to change management and require reassessment when they fire. |
| GAP-008 · High · due 2026-12-20 | Missing evidence | UC-DATA-Q1: Are the data sources, classifications and data flows used for training, grounding (RAG) and prompts documented for this system? | EI-06, IS-02 | Data Owner / CDO office | Document every data source, its classification and the data flows into prompts, retrieval indexes, logs and external services. |
| GAP-009 · High · due 2026-12-20 | Missing evidence | UC-SEC-Q2: Do models, prompts, plugins and third-party components come from an approved, integrity-checked supply chain? | IS-10, EI-05 | Security Architecture | Restrict models and components to an approved list with integrity checks and dependency scanning. |
| GAP-010 · High · due 2026-12-20 | Missing evidence | UC-SEC-Q4: Were pre-release validation and robustness tests run against documented acceptance criteria, with results retained? | GL-05, IS-07 | QA / ML Engineering | Define acceptance criteria, run pre-release validation and robustness tests, and retain signed-off results. |

| Gap · severity · due | Evidence status | Question | Controls | Owner role | Recommended action |
|---|---|---|---|---|---|
| GAP-011 · High · due 2026-12-20 | Missing evidence | UC-FAIR-Q2: Has a safety and harm evaluation been completed (harmful, misleading or inappropriate outputs, including for vulnerable users)? | IS-06 | Responsible AI Lead | Complete a harm analysis and safety evaluation, including vulnerable-user scenarios, and obtain residual-risk sign-off. |
| GAP-012 · High · due 2026-12-20 | Missing evidence | UC-FAIR-Q3: Are people informed when they are interacting with AI or receiving AI-generated content? | IS-08 | Product Owner / Legal | Add clear AI-interaction and AI-generated-content disclosures at the point of interaction; have Legal review the wording. |
| GAP-013 · High · due 2026-12-20 | Missing evidence | UC-HUM-Q3: Is there a defined escalation path for concerns and AI incidents involving this system? | AO-06, SE-04 | AI Governance Lead | Define and communicate an escalation path and incident procedure for this system, with named contacts and timeframes. |
| GAP-014 · High · due 2026-12-20 | Missing evidence | UC-HUM-Q4: Were go-live deployment conditions defined, verified and signed off before production use? | GL-07 | Product Owner | Define go-live conditions (controls, monitoring, oversight) and verify them with a signed checklist before production use. |
| GAP-015 · High · due 2026-12-20 | Missing evidence | UC-VEN-Q2: Do contract terms cover data-use restrictions, no training on your data, retention, breach notification and audit rights? | GL-11, AO-09 | Procurement / Vendor Risk | Negotiate or confirm AI contract clauses for data use, training restrictions, retention, breach notification and audit rights. |
| GAP-016 · High · due 2026-12-20 | Missing evidence | UC-MON-Q1: Is production performance, drift and misuse monitored against thresholds with alerts and review? | GL-08, SE-12 | ML Ops / Product Owner | Instrument performance, drift and misuse monitoring with thresholds, alerts and a recurring review. |
| GAP-017 · High · due 2026-12-20 | Missing evidence | UC-MON-Q3: Is evidence for this system's controls retained in an evidence repository, and can an audit-ready evidence pack be produced on request? | SE-02, SE-05 | AI Governance Lead | Store control evidence for this system in the evidence repository with retention rules and assemble an audit-ready evidence pack. |
| GAP-018 · High · due 2026-12-20 | Missing evidence | UC-MON-Q5: Is technical documentation (system/model card, architecture, data, testing, limitations) maintained for this system? | GL-06 | Product / ML Engineering | Produce and maintain technical documentation including a system/model card, architecture, data, testing and known limitations. |
| GAP-019 · Medium · due 2027-01-19 | User-asserted | UC-CORE-Q3: Has the use case passed intake triage and received a risk tier that was confirmed by an accountable approver? | GL-01, EI-02, EI-12 | AI Risk Lead | Run the use case through intake triage and record a human-confirmed risk tier with rationale in the intake register. |
| GAP-020 · Medium · due 2027-01-19 | User-asserted | UC-CORE-Q4: Was a pre-deployment risk and impact assessment completed and approved at the gate appropriate to the risk tier? | GL-02, GL-03 | AI Risk Lead | Complete a tier-proportionate risk and impact assessment and obtain approval at the tier-appropriate gate before (further) production use. |
| GAP-021 · Medium · due 2027-01-19 | User-asserted | UC-CORE-Q6: Has the use case been screened against the organization's prohibited and restricted AI use policy? | AO-10 | Legal / AI Governance Lead | Screen the use case against the prohibited/restricted AI use list and record the outcome; escalate any match for legal review. |
| GAP-022 · Medium · due 2027-01-19 | User-asserted | UC-HUM-Q1: Is the human oversight design documented — who reviews which outputs or actions, when, and with authority to override or stop the system? | IS-09 | Business Owner | Document the oversight design (reviewer roles, review points, override and stop authority) and keep records of oversight in operation. |
| GAP-023 · Medium · due 2027-01-19 | User-asserted | UC-CORE-Q5: Have the legal, regulatory and contractual obligations that apply to this system (by jurisdiction) been identified and reviewed? | AO-07 | Legal / Compliance | Add the system to the obligations register and obtain a legal review of applicable obligations by jurisdiction. |

| Gap · severity · due | Evidence status | Question | Controls | Owner role | Recommended action |
|---|---|---|---|---|---|
| GAP-024 · Medium · due 2027-01-19 | User-asserted | UC-FAIR-Q1: Has the system been tested for bias or discriminatory outcomes across relevant groups, with documented thresholds? | IS-05 | Responsible AI Lead / Data Science | Define relevant groups and fairness metrics, test against thresholds and record mitigations. |
| GAP-025 · Medium · due 2027-01-19 | User-asserted | UC-FAIR-Q4: Can affected individuals obtain an explanation, reach a human, and contest or appeal outcomes? | IS-08, AO-11 | Product Owner / Legal | Provide a route to a human, explanations proportionate to impact, and a contest/appeal channel whose outcomes are logged. |
| GAP-026 · Medium · due 2027-01-19 | User-asserted | UC-HUM-Q2: Are operators and reviewers trained on the system's limitations, automation bias and escalation paths? | AO-05 | HR / Learning lead with AI Governance Lead | Deliver role-based training for operators and reviewers covering limitations, automation bias and escalation, and track completion. |
| GAP-027 · Medium · due 2027-01-19 | User-asserted | UC-VEN-Q3: Is the vendor AI product recorded in the third-party AI inventory with an accountable owner? | EI-08, AO-09 | Procurement / Vendor Risk | Record the vendor AI product in the third-party AI inventory with an accountable owner and contract/DPA references. |
| GAP-028 · Medium · due 2027-01-19 | User-asserted | UC-VEN-Q4: Are vendor model version changes and deprecations monitored and routed through change control? | GL-04, EI-05 | Engineering / Change Advisory Board | Monitor vendor model/version announcements and route changes through change control with reassessment triggers. |
| GAP-029 · Medium · due 2027-01-19 | User-asserted | UC-MON-Q2: Is this system covered by an AI incident management procedure, including internal and external reporting timelines? | SE-04 | CISO / Operational Risk | Bring the system under the AI incident procedure with defined severity levels and reporting timelines; Legal to confirm external reporting duties. |
| GAP-030 · Medium · due 2027-01-19 | Missing evidence | UC-MON-Q4: Is a periodic review / recertification of this system scheduled at the cadence required by its risk tier? | GL-12, EI-11 | AI Risk Lead | Schedule periodic review and recertification at the cadence set for the system's risk tier. |
| GAP-031 · Low · due 2027-04-19 | User-asserted | UC-SEC-Q1: Has an AI-specific threat model been completed for this system (e.g. prompt injection, data poisoning, model abuse, tool misuse)? | IS-01 | CISO / Security Architecture | Produce an AI-specific threat model covering injection, poisoning, abuse and tool misuse, and track mitigations to closure. |

Due dates apply the AEGIS severity SLAs (Critical 30, High 60, Medium 90, Low 180 days) from 2026-10-21.

## 6. Control recommendations

| Control | Title | Priority | Highest gap severity | Owner role | Framework mappings (indicative) |
|---|---|---|---|---|---|
| IS-03 | Privacy assessment and data minimisation | critical | Critical | DPO / Privacy Lead | NIST AI RMF: MEASURE 2.10, MAP 1.1; ISO/IEC 42001: A.7.4, A.5.4; EU AI Act: Art. 10 |
| IS-11 | Least-privilege tool access | critical | Critical | Platform Engineering / IAM | NIST AI RMF: MEASURE 2.7, MANAGE 2.2; ISO/IEC 42001: A.6.2.6, A.4.4; EU AI Act: Art. 15, Art. 14 |
| SE-02 | Evidence repository and retention | high | Critical | AI Governance Lead | NIST AI RMF: GOVERN 1.4; ISO/IEC 42001: 7.5; EU AI Act: Art. 18, Art. 19 |
| IS-04 | Sensitive data redaction and masking | critical | High | Platform Engineering / Privacy Lead | NIST AI RMF: MEASURE 2.10; ISO/IEC 42001: A.7.4, A.6.2.6; EU AI Act: Art. 10 |
| IS-15 | Kill switch and rollback | critical | High | Platform Engineering / SRE | NIST AI RMF: MANAGE 2.4; ISO/IEC 42001: A.6.2.6; EU AI Act: Art. 14 |
| AO-06 | Escalation paths and decision rights | high | High | AI Governance Lead | NIST AI RMF: GOVERN 2.1, GOVERN 4.3; ISO/IEC 42001: 5.3, A.3.3; EU AI Act: Art. 26 |

| Control | Title | Priority | Highest gap severity | Owner role | Framework mappings (indicative) |
|---|---|---|---|---|---|
| EI-04 | Intended purpose and context of use | high | High | Product Owner | NIST AI RMF: MAP 1.1, MAP 1.2, MAP 3.4; ISO/IEC 42001: A.6.2.2, A.9.4; EU AI Act: Art. 11, Art. 13 |
| EI-05 | Model, prompt and component registry | high | High | ML / Platform Engineering Lead | NIST AI RMF: MAP 4.1, GOVERN 1.6; ISO/IEC 42001: A.4.4, A.6.2.3; EU AI Act: Art. 11 |
| EI-06 | Data source and lineage registry | high | High | Data Owner / CDO office | NIST AI RMF: MAP 2.3, MEASURE 2.10; ISO/IEC 42001: A.4.3, A.7.5; EU AI Act: Art. 10 |
| GL-04 | Change management and reassessment triggers | high | High | Engineering / Change Advisory Board | NIST AI RMF: GOVERN 1.4, MANAGE 2.4; ISO/IEC 42001: 6.3, A.6.2.6; EU AI Act: Art. 43 |
| GL-05 | Pre-release validation and testing | high | High | QA / ML Engineering | NIST AI RMF: MEASURE 2.1, MEASURE 2.3, MEASURE 2.5; ISO/IEC 42001: A.6.2.4; EU AI Act: Art. 9, Art. 15 |
| GL-06 | Technical documentation | high | High | Product / ML Engineering | NIST AI RMF: MAP 2.2, MEASURE 2.9; ISO/IEC 42001: 7.5, A.6.2.7, A.6.2.3; EU AI Act: Art. 11 |
| GL-07 | Deployment conditions and go-live readiness | high | High | Product Owner | NIST AI RMF: MANAGE 1.2, MANAGE 2.1; ISO/IEC 42001: A.6.2.5; EU AI Act: Art. 26 |
| GL-08 | Post-deployment monitoring | high | High | ML Ops / Product Owner | NIST AI RMF: MEASURE 3.1, MANAGE 4.1; ISO/IEC 42001: 9.1, A.6.2.6; EU AI Act: Art. 26, Art. 72 |
| GL-11 | Vendor AI due diligence and contract controls | high | High | Procurement / Vendor Risk | NIST AI RMF: GOVERN 6.1, MAP 4.1; ISO/IEC 42001: A.10.3, A.10.4; EU AI Act: Art. 25 |
| IS-02 | Data governance and quality | high | High | Data Owner | NIST AI RMF: MAP 2.3, MEASURE 2.1; ISO/IEC 42001: A.7.2, A.7.3, A.7.4, A.7.6; EU AI Act: Art. 10 |
| IS-06 | Safety and harm evaluation | high | High | Responsible AI Lead | NIST AI RMF: MEASURE 2.6, MAP 5.1; ISO/IEC 42001: A.5.4, A.5.5; EU AI Act: Art. 9 |
| IS-07 | Accuracy and robustness testing | high | High | ML Engineering | NIST AI RMF: MEASURE 2.5; ISO/IEC 42001: A.6.2.4; EU AI Act: Art. 15 |
| IS-08 | Transparency and AI disclosures | high | High | Product Owner / Legal | NIST AI RMF: MEASURE 2.8, MEASURE 2.9; ISO/IEC 42001: A.8.2, A.8.5; EU AI Act: Art. 13, Art. 50 |
| IS-10 | Secure model and prompt supply chain | high | High | Security Architecture | NIST AI RMF: GOVERN 6.1, MEASURE 2.7; ISO/IEC 42001: A.10.3, A.6.2.3; EU AI Act: Art. 15 |
| SE-04 | AI incident management and reporting | high | High | CISO / Operational Risk | NIST AI RMF: MANAGE 4.3, MANAGE 2.3; ISO/IEC 42001: 10.2, A.8.4; EU AI Act: Art. 73, Art. 26 |
| SE-05 | Audit-ready evidence packs | high | High | AI Governance Lead | NIST AI RMF: GOVERN 1.4, MEASURE 2.9; ISO/IEC 42001: 7.5, 9.2; EU AI Act: Art. 11, Art. 18 |
| SE-12 | Model performance and drift monitoring | high | High | ML Ops | NIST AI RMF: MEASURE 2.4, MEASURE 3.1; ISO/IEC 42001: A.6.2.6; EU AI Act: Art. 72, Art. 15 |
| AO-09 | Third-party AI accountability | medium | High | Procurement / Vendor Risk | NIST AI RMF: GOVERN 6.1, GOVERN 6.2; ISO/IEC 42001: A.10.2, A.10.3; EU AI Act: Art. 25, Art. 26 |
| AO-10 | Prohibited and restricted AI use policy | critical | Medium | Legal / AI Governance Lead | NIST AI RMF: GOVERN 1.1, MAP 1.1; ISO/IEC 42001: A.9.4, A.2.2; EU AI Act: Art. 5 |

| Control | Title | Priority | Highest gap severity | Owner role | Framework mappings (indicative) |
|---|---|---|---|---|---|
| EI-02 | AI risk classification and tiering | critical | Medium | AI Risk Lead | NIST AI RMF: MAP 1.1, MAP 1.5, GOVERN 1.3; ISO/IEC 42001: 6.1.2, A.5.2; EU AI Act: Art. 6 |
| GL-02 | Pre-deployment risk and impact assessment | critical | Medium | AI Risk Lead | NIST AI RMF: MAP 1.1, MAP 3.1, MAP 5.1, MEASURE 1.1; ISO/IEC 42001: 6.1.4, 8.4, A.5.2, A.5.3, A.5.4; EU AI Act: Art. 9, Art. 27 |
| GL-03 | Risk-tiered approval gates | critical | Medium | AI Governance Forum | NIST AI RMF: MANAGE 1.1, GOVERN 1.4; ISO/IEC 42001: 8.1, A.6.2.5; EU AI Act: Art. 9, Art. 43 |
| IS-09 | Human oversight design | critical | Medium | Business Owner | NIST AI RMF: GOVERN 3.2, MAP 3.5; ISO/IEC 42001: A.9.2, A.6.2.6; EU AI Act: Art. 14, Art. 26 |
| AO-05 | AI literacy and role-based training | high | Medium | HR / Learning lead with AI Governance Lead | NIST AI RMF: GOVERN 2.2; ISO/IEC 42001: 7.2, 7.3, A.4.6; EU AI Act: Art. 4 |
| AO-07 | Regulatory and contractual obligations register | high | Medium | Legal / Compliance | NIST AI RMF: GOVERN 1.1; ISO/IEC 42001: 4.1, 4.2, 6.1; EU AI Act: Art. 6, Art. 26 |
| EI-08 | Third-party and vendor AI inventory | high | Medium | Procurement / Vendor Risk | NIST AI RMF: GOVERN 6.1; ISO/IEC 42001: A.10.3; EU AI Act: Art. 25 |
| EI-12 | Use-case intake register | high | Medium | AI CoE | NIST AI RMF: MAP 1.1; ISO/IEC 42001: A.5.2, A.6.1.3; EU AI Act: Art. 6 |
| GL-01 | Intake triage workflow | high | Medium | AI CoE | NIST AI RMF: MAP 1.1, MAP 1.6; ISO/IEC 42001: 8.1, A.6.1.3; EU AI Act: Art. 9 |
| IS-05 | Bias and fairness testing | high | Medium | Responsible AI Lead / Data Science | NIST AI RMF: MEASURE 2.11; ISO/IEC 42001: A.5.4, A.7.4; EU AI Act: Art. 10 |
| AO-11 | Stakeholder engagement and feedback | medium | Medium | Product Owner | NIST AI RMF: GOVERN 5.1, GOVERN 5.2; ISO/IEC 42001: 4.2, A.8.3, A.8.5; EU AI Act: Art. 27 |
| EI-11 | Inventory attestation and recertification | medium | Medium | AI Governance Lead | NIST AI RMF: GOVERN 1.5; ISO/IEC 42001: 9.1 |
| GL-12 | Periodic review and recertification | medium | Medium | AI Risk Lead | NIST AI RMF: GOVERN 1.5; ISO/IEC 42001: 9.3; EU AI Act: Art. 9 |
| IS-01 | AI threat modelling | high | Low | CISO / Security Architecture | NIST AI RMF: MAP 5.1, MEASURE 2.7; ISO/IEC 42001: 6.1.2, A.6.1.3; EU AI Act: Art. 15 |

## 7. Remediation roadmap (30/60/90 days)

### First 30 days — contain Critical exposure

- GAP-001 (Critical): Restrict data access to the minimum records and fields required, using scoped service identities, and review access periodically. — IS-03, IS-11; owner: DPO / Privacy Lead; due 2026-11-20
- GAP-002 (Critical): Define and enforce retention periods for prompts, outputs, transcripts and logs consistent with the privacy assessment. — IS-03, SE-02; owner: DPO / Privacy Lead; due 2026-11-20

### Days 31–60 — close High gaps

- GAP-003 (High): Complete a privacy impact assessment (DPIA where required) covering lawful basis, minimisation, retention and transfers, signed off by the DPO/privacy lead. — IS-03; owner: DPO / Privacy Lead; due 2026-12-20
- GAP-004 (High): Deploy redaction/masking on prompts, responses, logs and external model calls; test it against representative records and retain the results. — IS-04; owner: Platform Engineering / Privacy Lead; due 2026-12-20

- GAP-005 (High): Implement and test a kill switch and rollback runbook; record time-to-disable from the test. — IS-15; owner: Platform Engineering / SRE; due 2026-12-20
- GAP-006 (High): Document intended purpose, context of use, users, affected parties and explicitly out-of-scope or foreseeable misuse. — EI-04; owner: Product Owner; due 2026-12-20
- GAP-007 (High): Add AI-specific change triggers (model, prompt, data, tool, vendor) to change management and require reassessment when they fire. — GL-04, EI-05; owner: Engineering / Change Advisory Board; due 2026-12-20
- GAP-008 (High): Document every data source, its classification and the data flows into prompts, retrieval indexes, logs and external services. — EI-06, IS-02; owner: Data Owner / CDO office; due 2026-12-20
- GAP-009 (High): Restrict models and components to an approved list with integrity checks and dependency scanning. — IS-10, EI-05; owner: Security Architecture; due 2026-12-20
- GAP-010 (High): Define acceptance criteria, run pre-release validation and robustness tests, and retain signed-off results. — GL-05, IS-07; owner: QA / ML Engineering; due 2026-12-20
- GAP-011 (High): Complete a harm analysis and safety evaluation, including vulnerable-user scenarios, and obtain residual-risk sign-off. — IS-06; owner: Responsible AI Lead; due 2026-12-20
- GAP-012 (High): Add clear AI-interaction and AI-generated-content disclosures at the point of interaction; have Legal review the wording. — IS-08; owner: Product Owner / Legal; due 2026-12-20
- GAP-013 (High): Define and communicate an escalation path and incident procedure for this system, with named contacts and timeframes. — AO-06, SE-04; owner: AI Governance Lead; due 2026-12-20
- GAP-014 (High): Define go-live conditions (controls, monitoring, oversight) and verify them with a signed checklist before production use. — GL-07; owner: Product Owner; due 2026-12-20
- GAP-015 (High): Negotiate or confirm AI contract clauses for data use, training restrictions, retention, breach notification and audit rights. — GL-11, AO-09; owner: Procurement / Vendor Risk; due 2026-12-20
- GAP-016 (High): Instrument performance, drift and misuse monitoring with thresholds, alerts and a recurring review. — GL-08, SE-12; owner: ML Ops / Product Owner; due 2026-12-20
- GAP-017 (High): Store control evidence for this system in the evidence repository with retention rules and assemble an audit-ready evidence pack. — SE-02, SE-05; owner: AI Governance Lead; due 2026-12-20
- GAP-018 (High): Produce and maintain technical documentation including a system/model card, architecture, data, testing and known limitations. — GL-06; owner: Product / ML Engineering; due 2026-12-20

### Days 61–90 — standardise and evidence

- GAP-019 (Medium): Run the use case through intake triage and record a human-confirmed risk tier with rationale in the intake register. — GL-01, EI-02, EI-12; owner: AI Risk Lead; due 2027-01-19
- GAP-020 (Medium): Complete a tier-proportionate risk and impact assessment and obtain approval at the tier-appropriate gate before (further) production use. — GL-02, GL-03; owner: AI Risk Lead; due 2027-01-19
- GAP-021 (Medium): Screen the use case against the prohibited/restricted AI use list and record the outcome; escalate any match for legal review. — AO-10; owner: Legal / AI Governance Lead; due 2027-01-19
- GAP-022 (Medium): Document the oversight design (reviewer roles, review points, override and stop authority) and keep records of oversight in operation. — IS-09; owner: Business Owner; due 2027-01-19
- GAP-023 (Medium): Add the system to the obligations register and obtain a legal review of applicable obligations by jurisdiction. — AO-07; owner: Legal / Compliance; due 2027-01-19
- GAP-024 (Medium): Define relevant groups and fairness metrics, test against thresholds and record mitigations. — IS-05; owner: Responsible AI Lead / Data Science; due 2027-01-19
- GAP-025 (Medium): Provide a route to a human, explanations proportionate to impact, and a contest/appeal channel whose outcomes are logged. — IS-08, AO-11; owner: Product Owner / Legal; due 2027-01-19

- GAP-026 (Medium): Deliver role-based training for operators and reviewers covering limitations, automation bias and escalation, and track completion. — AO-05; owner: HR / Learning lead with AI Governance Lead; due 2027-01-19
- GAP-027 (Medium): Record the vendor AI product in the third-party AI inventory with an accountable owner and contract/DPA references. — EI-08, AO-09; owner: Procurement / Vendor Risk; due 2027-01-19
- GAP-028 (Medium): Monitor vendor model/version announcements and route changes through change control with reassessment triggers. — GL-04, EI-05; owner: Engineering / Change Advisory Board; due 2027-01-19
- GAP-029 (Medium): Bring the system under the AI incident procedure with defined severity levels and reporting timelines; Legal to confirm external reporting duties. — SE-04; owner: CISO / Operational Risk; due 2027-01-19
- GAP-030 (Medium): Schedule periodic review and recertification at the cadence set for the system's risk tier. — GL-12, EI-11; owner: AI Risk Lead; due 2027-01-19

### Beyond 90 days — evidence hygiene backlog

- GAP-031 (Low): Produce an AI-specific threat model covering injection, poisoning, abuse and tool misuse, and track mitigations to closure. — IS-01; owner: CISO / Security Architecture; due 2027-04-19

## 8. Audit-ready evidence checklist

| Done | Question | Controls | Evidence expected | Evidence provided | Status |
|---|---|---|---|---|---|
| [x] | UC-CORE-Q1 | EI-03, EI-01 | Inventory record with owner fields populated; Owner acceptance record | EVD-1922 | Verified |
| [ ] | UC-CORE-Q2 | EI-04 | System profile with intended purpose; Users and affected parties; Foreseeable misuse analysis | — | Missing evidence |
| [ ] | UC-CORE-Q3 | GL-01, EI-02, EI-12 | Intake register entry; Triage decision with rationale; Tiering approval record | — | User-asserted |
| [ ] | UC-CORE-Q4 | GL-02, GL-03 | Completed risk/impact assessment; Reviewer sign-off; Approval record with conditions; Residual-risk statement | — | User-asserted |
| [ ] | UC-CORE-Q5 | AO-07 | Obligations register entry for this system; Legal review record | — | User-asserted |
| [ ] | UC-CORE-Q6 | AO-10 | Intake screening record against prohibited/restricted use list | — | User-asserted |
| [ ] | UC-CORE-Q7 | GL-04, EI-05 | Change policy with AI-specific triggers; Change tickets referencing reassessment; Model/prompt version history | — | Missing evidence |
| [ ] | UC-DATA-Q1 | EI-06, IS-02 | Data source register entries; Data-flow diagram; Data classification per source | — | Missing evidence |
| [ ] | UC-DATA-Q2 | IS-03 | Privacy/data-protection impact assessment; Retention schedule; Transfer assessment | — | Missing evidence |
| [ ] | UC-DATA-Q3 | IS-04 | Redaction configuration; Redaction test results; Log samples showing masking | — | Missing evidence |
| [ ] | UC-DATA-Q4 | IS-03, IS-11 | Access-scope configuration; Field-level access matrix; Access review record | — | Critical gap |
| [ ] | UC-DATA-Q5 | IS-03, SE-02 | Retention schedule covering AI artefacts; Deletion job configuration or records | — | Critical gap |
| [ ] | UC-SEC-Q1 | IS-01 | Threat model document; Mitigation tracking | EVD-6415 | User-asserted |
| [ ] | UC-SEC-Q2 | IS-10, EI-05 | Approved model/provider list; Integrity checks; Dependency scanning results | — | Missing evidence |
| [ ] | UC-SEC-Q3 | IS-15 | Kill-switch procedure; Kill-switch test record with time-to-disable; Rollback runbook | — | Missing evidence |
| [ ] | UC-SEC-Q4 | GL-05, IS-07 | Test plan and results; Acceptance criteria; Release sign-off | — | Missing evidence |
| [ ] | UC-FAIR-Q1 | IS-05 | Fairness test plan and results; Mitigation records | — | User-asserted |

| Done | Question | Controls | Evidence expected | Evidence provided | Status |
|---|---|---|---|---|---|
| [ ] | UC-FAIR-Q2 | IS-06 | Harm analysis; Safety evaluation results; Residual-risk sign-off | — | Missing evidence |
| [ ] | UC-FAIR-Q3 | IS-08 | Disclosure text and placement; User-facing documentation | — | Missing evidence |
| [ ] | UC-FAIR-Q4 | IS-08, AO-11 | Explanation approach; Feedback channel; Feedback log | — | User-asserted |
| [ ] | UC-HUM-Q1 | IS-09 | Oversight design document; Override/appeal procedures; Oversight operation records | — | User-asserted |
| [ ] | UC-HUM-Q2 | AO-05 | Training curriculum; Completion records by role | — | User-asserted |
| [ ] | UC-HUM-Q3 | AO-06, SE-04 | Escalation matrix; AI incident procedure; Sample escalation records | — | Missing evidence |
| [ ] | UC-HUM-Q4 | GL-07 | Go-live checklist; Condition verification record | — | Missing evidence |
| [x] | UC-VEN-Q1 | GL-11 | Vendor AI questionnaire; Due-diligence approval | EVD-8218 | Verified |
| [ ] | UC-VEN-Q2 | GL-11, AO-09 | Contract AI clauses; Responsibility allocation (e.g. RACI or contract schedule) | — | Missing evidence |
| [ ] | UC-VEN-Q3 | EI-08, AO-09 | Vendor AI register; Vendor AI owner assignments | — | User-asserted |
| [ ] | UC-VEN-Q4 | GL-04, EI-05 | Change tickets referencing reassessment; Model registry entries with versions | — | User-asserted |
| [ ] | UC-MON-Q1 | GL-08, SE-12 | Monitoring dashboards; Alert thresholds; Monitoring review records | — | Missing evidence |
| [ ] | UC-MON-Q2 | SE-04 | AI incident procedure; Incident log; Post-incident reviews | — | User-asserted |
| [ ] | UC-MON-Q3 | SE-02, SE-05 | Evidence repository; Retention policy; Sample evidence pack | — | Missing evidence |
| [ ] | UC-MON-Q4 | GL-12, EI-11 | Review calendar by tier; Recertification records | — | Missing evidence |
| [ ] | UC-MON-Q5 | GL-06 | Technical documentation pack; Model/system card | EVD-7330 | Missing evidence |

Only items marked [x] have evidence reviewed by a named reviewer.

## 9. Runtime guardrail recommendations

- **RG-PII-REDACTION** — Redact personal and sensitive data in prompts, responses and logs (IS-04, IS-03)
- **RG-ACTION-LOGGING** — Log every model and tool call with trace ID, redacted inputs and policy decision (SE-08)
- **RG-KILL-SWITCH** — Provide a kill switch to disable the system, agent or individual tools (IS-15)

AEGIS Shield advisor rating: High (see the draft runtime policy for details; activation in production requires human approval).

Draft guardrail policies can be generated with AEGIS Shield; activating or changing a production runtime policy requires human approval (IS-12, GL-04).

## 10. Human approvals

| Approval | Type | Status | Resource | Requested by | Resolved by |
|---|---|---|---|---|---|
| apr_mvi8hs9q253119f1 | confirm_risk_tier | approved | sys_mvi8hs8313cd7b41 | u-assessor-1 | u-approver-1 |

## Appendix A — Evidence status definitions

| Status | Definition |
|---|---|
| Verified | Evidence exists and has been reviewed |
| User-asserted | User claims implementation, but evidence is absent |
| Inferred | Inferred as a likely gap or fact from responses or metadata |
| Missing evidence | Required evidence has not been provided |
| Critical gap | Material privacy, security, safety, legal, or operational exposure |

## Appendix B — Audit trace

Tool calls and agent turns for this assessment are recorded in the hash-chained AEGIS audit log (SE-08).

| Timestamp (UTC) | Trace ID | Action | Actor | Outcome | Audit record |
|---|---|---|---|---|---|
| 2026-10-21T14:55:25 | trc_mvi8hw6y43537714 | agent.tool.start_assessment | u-assessor-1 | success | aud_mvi8hw70e4a8b94a |
| 2026-10-21T14:55:25 | trc_mvi8hw706102584b | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw731053b45e |
| 2026-10-21T14:55:25 | trc_mvi8hw7340361 99f | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw741181360d |
| 2026-10-21T14:55:25 | trc_mvi8hw74aa629557 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7547e5e504 |
| 2026-10-21T14:55:25 | trc_mvi8hw7619cdef05 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw76341a17bd |
| 2026-10-21T14:55:25 | trc_mvi8hw77d2c141b9 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw777cd8502e |
| 2026-10-21T14:55:25 | trc_mvi8hw78172a16f9 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw79cca9f9fb |
| 2026-10-21T14:55:25 | trc_mvi8hw7afc48586c | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7a02100 96c |
| 2026-10-21T14:55:25 | trc_mvi8hw7b2d3cd3d9 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7ce0384546 |
| 2026-10-21T14:55:25 | trc_mvi8hw7ca37611a0 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7de1b1ad16 |
| 2026-10-21T14:55:25 | trc_mvi8hw7d3e2d11bd | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7e7661b236 |
| 2026-10-21T14:55:25 | trc_mvi8hw7eeffd894d | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7f8391c11a |
| 2026-10-21T14:55:25 | trc_mvi8hw7g4dfd7ba9 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7h3c3b7a8f |
| 2026-10-21T14:55:25 | trc_mvi8hw7h6826475c | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7k378d41e6 |
| 2026-10-21T14:55:25 | trc_mvi8hw7lb0ec0340 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7mac46a432 |
| 2026-10-21T14:55:25 | trc_mvi8hw7m094147d9 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7p7518220d |
| 2026-10-21T14:55:25 | trc_mvi8hw7q84a48e90 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7r65f2c694 |
| 2026-10-21T14:55:25 | trc_mvi8hw7r4acdac2d | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7sc427eeb4 |
| 2026-10-21T14:55:25 | trc_mvi8hw7t933f192a | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7uf228ed47 |
| 2026-10-21T14:55:25 | trc_mvi8hw7vc75ecaad | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7w97a1a4e1 |
| 2026-10-21T14:55:25 | trc_mvi8hw7w525b1669 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7y18a51bce |

| Timestamp (UTC) | Trace ID | Action | Actor | Outcome | Audit record |
|---|---|---|---|---|---|
| 2026-10-21T14:55:25 | trc_mvi8hw7y6dec9858 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw7zbb1a319f |
| 2026-10-21T14:55:25 | trc_mvi8hw80e5bb2122 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw81981fb4da |
| 2026-10-21T14:55:25 | trc_mvi8hw8153ee3475 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw82bc6e19db |
| 2026-10-21T14:55:25 | trc_mvi8hw83f6669631 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8725da7e44 |
| 2026-10-21T14:55:25 | trc_mvi8hw882233d69f | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8d4b2bc990 |
| 2026-10-21T14:55:25 | trc_mvi8hw8ea981cafa | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8ha5f40f6a |
| 2026-10-21T14:55:25 | trc_mvi8hw8i0a6e8461 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8k389ea323 |
| 2026-10-21T14:55:25 | trc_mvi8hw8k3c1875f8 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8l7a760538 |
| 2026-10-21T14:55:25 | trc_mvi8hw8m46591130 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8n972c9e6a |
| 2026-10-21T14:55:25 | trc_mvi8hw8o98a93845 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8pc3c1fb5a |
| 2026-10-21T14:55:25 | trc_mvi8hw8qfdd8f778 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8s920369b5 |
| 2026-10-21T14:55:25 | trc_mvi8hw8sc4f86511 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw8uc732454c |
| 2026-10-21T14:55:25 | trc_mvi8hw8u03ca03f1 | agent.tool.submit_assessment_response | u-assessor-1 | success | aud_mvi8hw902592d408 |
| 2026-10-21T14:55:25 | trc_mvi8hw97a79921cc | evidence.reviewed | u-approver-1 | success | aud_mvi8hw9709cda42f |
| 2026-10-21T14:55:25 | trc_mvi8hw99ab5fe65b | evidence.reviewed | u-approver-1 | success | aud_mvi8hw99b8762ab7 |
| 2026-10-21T14:55:25 | trc_mvi8hw9a618a9a77 | agent.tool.identify_gaps | u-assessor-1 | success | aud_mvi8hw9ked744ef1 |

## Appendix C — Method and limitations

- Answers are self-reported; AEGIS has not inspected systems or documents unless evidence is marked Verified.
- The risk tier is preliminary and rule-based; the EU AI Act category screen is a trigger for legal review, not a legal classification.
- Framework mappings are indicative AEGIS interpretations from the Control Library, not official crosswalks.
- Regulatory applicability timelines must be verified against the current Official Journal text and any amendments.

## Disclaimer

AEGIS supports governance readiness, control implementation and evidence collection. It does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice. Framework mappings are indicative.

This use-case assessment produces an indicative view of governance readiness for a single AI system. Self-reported answers are User-asserted; only evidence reviewed by a named reviewer is Verified. Risk tiers are Inferred and require human confirmation. Framework mappings are indicative. AEGIS does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice.

*Synthetic example — fictional data.*